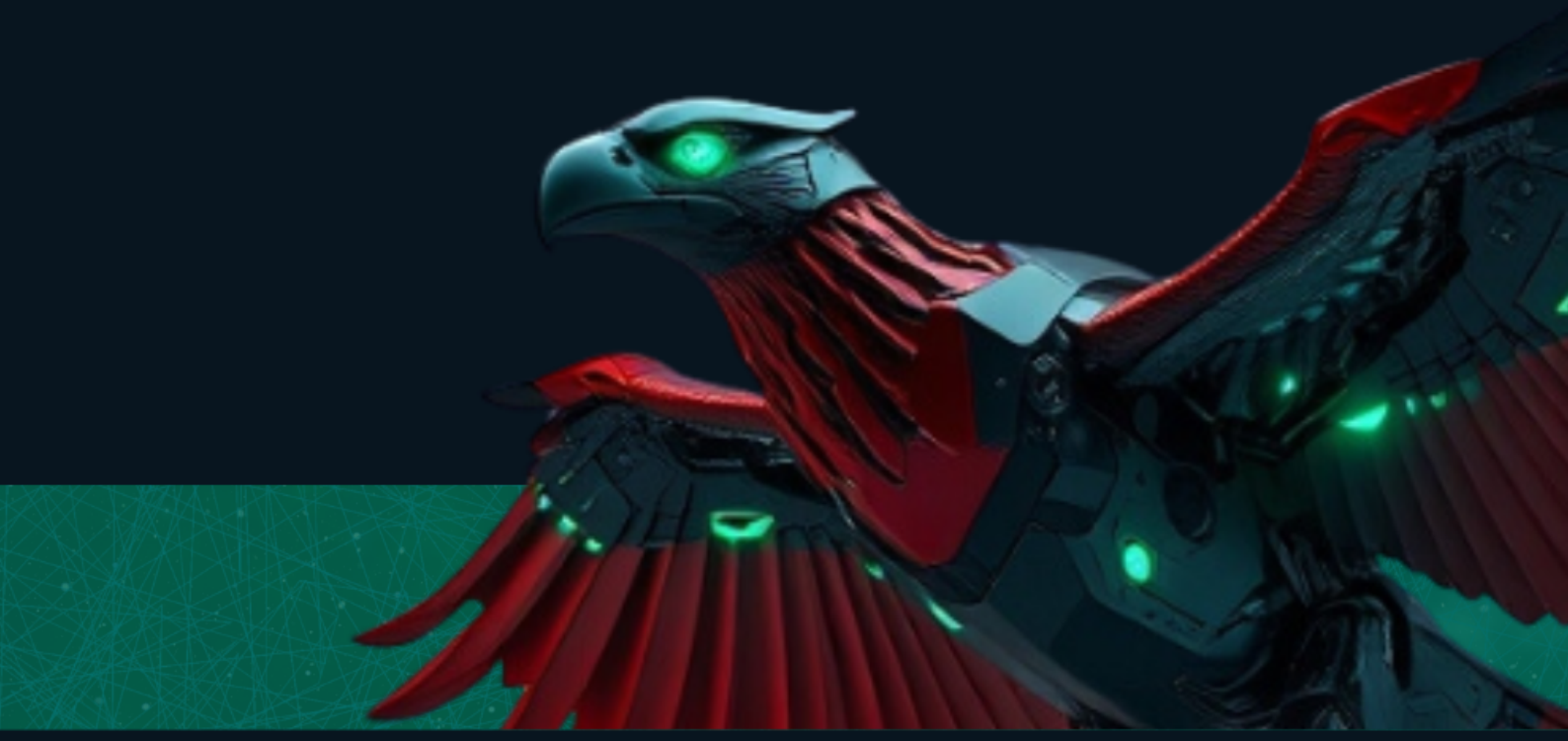
SOCBYTE
ALL BYTES SECURED

INTEL REPORT



Report Details

Title	CVE-2026-47101
Sub Title	LiteLLM prior to 1.83.14 allows an authenticated internal_user to create API keys with access to routes that their role does not permit
Status	Closed
Type	Advisory
Severity	—
Source	Multiple Sources
Created At	Jun 16, 2026, 01:00 PM

CVE-2026-47101

LiteLLM prior to 1.83.14 allows an authenticated internal_user to create API keys with access to routes that their role does not permit

Type: ADVISORY • Source: Multiple Sources • Created At: Jun 16, 2026, 01:00 PM

Analysis Summary

CVE-2026-47101 is an incorrect authorization vulnerability (classified under CWE-863) discovered in LiteLLM, a popular proxy server used to manage, load-balance, and track usage across various Large Language Model (LLM) APIs. The flaw resides within the application's API key generation process. When a user requests a new API key, the system allows them to specify an allowed_routes parameter to define which endpoints that token can access. However, LiteLLM fails to implement field-level verification to ensure the requesting user actually possesses the rights to those endpoints themselves. As a result, the backend blindly stores the unverified routes associated with the new key.

This vulnerability directly affects organizations and administrators hosting self-managed deployments of LiteLLM prior to version 1.83.14. Specifically, it introduces a significant internal risk by allowing any authenticated user assigned a standard internal_user role to bypass role-based access controls (RBAC). In environments where multi-tenancy or strict permission boundaries are enforced between different teams, developers, or automated services, this flaw breaks down the isolation mechanisms meant to protect administrative functions.

The impact of successful exploitation is a full privilege escalation from a standard user to a proxy_admin. Because the newly generated token is cryptographically valid and contains unauthorized admin-only paths, an attacker can use it to reach restricted endpoints such as /user/update or routing management configurations. This allows the threat actor to gain complete control over the LiteLLM proxy, modify global configurations, view sensitive operational telemetry, manipulate other user accounts, or potentially orchestrate a complete compromise of the underlying LLM infrastructure.

Affected Product

- LiteLLM prior to 1.83.14

Impact

- Privilege Escalation (TA0004)
- Exploitation for Privilege Escalation (T1068)
- Credential Access (TA0006)
- Modify Authentication Process (T1556)
- Lateral Movement (TA0008) / Defense Evasion (TA0005)
- Use Alternate Authentication Material: Web Session Cookie / API Tokens (T1550.004)

Vulnerabilities (CVEs)

CVE Number	Description	Published	CVSS Score
CVE-2026-47101	LiteLLM prior to 1.83.14 allows an authenticated internal_user to create API keys	6/10/2026	8.8

Remediation

• Upgrade LiteLLM (Primary Remediation): Update your LiteLLM deployment to version 1.83.14 or later. The patch closes the authorization bypass by enforcing field-level verification on the allowed_routes field during key generation, preventing non-admin users from assigning themselves unpermitted endpoints.

• Audit and Revoke Existing API Keys: Review all existing API keys generated prior to the update—especially those created by internal_user roles. Audit the allowed_routes field associated with these keys and revoke any that contain unauthorized access to proxy_admin or admin-only endpoints.

• Enforce Strict Least Privilege: Restrict user role assignments within LiteLLM. Ensure that users are strictly categorized under their minimum required access roles to limit the blast radius of potential key-generation misconfigurations.

• Monitor Route Logs: Implement logging and monitoring on your reverse proxy or API gateway. Look for instances where non-admin credentials or keys associated with standard internal users are attempting to access administrative endpoints or routes (e.g., /user/update, /key/generate, or routing management configurations).